Google Workspace Security Baseline, DLP & Context-Aware Access (CAA)

Implementation Solution Guide

Version 1.0.0 · 2026-07-06

Contents

Executive Summary — Google Workspace Security Baseline, DLP & Context-Aware Access (CAA) 4

The problem . . . 4

The solution . . . 4

How it is delivered . . . 4

Business outcome . . . 4

Scope note . . . 5

1. Solution Overview — Google Workspace Security Baseline, DLP & Context-Aware Access (CAA) 5

The Workspace security model — three layers, one posture . . . 5

How the three layers enforce Zero-Trust . . . 6

Deployment model — Assess → Configure → Pilot → Validate → Expand . . . 6

What this solution delivers . . . 7

2. Requirements Guide — Google Workspace Security Baseline, DLP & Context-Aware Access (CAA) 7

2.1 A Workspace edition that supports the controls you will enforce . . . 7

2.2 Super-admin (and least-privilege operator roles) . . . 7

2.3 2SV readiness (enrollment path + break-glass) . . . 8

2.4 Identity & session signals . . . 8

2.5 Context signals for CAA (network + device) . . . 8

2.6 DLP scope & detectors (what "sensitive" means here) . . . 8

2.7 Pilot scope (OU) and named baseline objects . . . 9

2.8 Security stakeholders + change control / rollback . . . 9

Checklist . . . 9

Global Requirements — Google Workspace & Gemini Solutions 10

1. Google Workspace / Cloud Identity tenant . . . 10

2. Source Microsoft 365 / Entra environment (for migration & coexistence) . . . 10

3. DNS control for the routed domains . . . 10

4. Identity & provisioning source of truth . . . 11

5. A pilot scope (OU / group) and change control . . . 11

6. Security, compliance & governance stakeholders . . . 11

3. Implementation Guide — Google Workspace Security Baseline, DLP & Context-Aware Access (CAA) 12

Named objects this solution creates and reuses . . . 12

Step 0 — Assess current posture (read-only) . . . 12

Step 1 — Create the pilot OU and move representative users . . . 12

Step 2 — Apply the hardening baseline (Layer 1) to the pilot OU . . . 13
Step 3 — Create CAA access levels (Layer 3, monitor mode) — *edition-gated* . . . 13
Step 4 — Author DLP rules (Layer 2, audit mode) — *edition-gated* . . . 14
Step 5 — Pilot: exercise the controls on the pilot OU . . . 14
Step 6 — Assign CAA (monitor → enforce) and graduate DLP (audit → block) . . . 15
Step 7 — Expand to the fleet, OU by OU . . . 15
Rollback (keep ready at every gate) . . . 15
5. Testing & Validation — Google Workspace Security Baseline, DLP & Context-Aware Access (CAA) 16
A. Hardening baseline (Layer 1) . . . 16
B. DLP for Drive & Gmail (Layer 2) — *edition-gated* . . . 16
C. Context-Aware Access (Layer 3) — *edition-gated* . . . 17
D. Coverage & exceptions (fleet) . . . 17
Exit criteria (before expanding past the pilot) . . . 17
6. Troubleshooting — Google Workspace Security Baseline, DLP & Context-Aware Access (CAA) 18
Hardening baseline (Layer 1) . . . 18
Data Loss Prevention (Layer 2) — *edition-gated* . . . 19
Context-Aware Access (Layer 3) — *edition-gated* . . . 19
Scripts . . . 20
7. Best Practices — Google Workspace Security Baseline, DLP & Context-Aware Access (CAA) 20
Staged enforcement (the core discipline) . . . 20
Identity & session hygiene . . . 21
Data protection (DLP) . . . 21
Context-Aware Access (CAA) . . . 21
Change control & rollback . . . 21
Operate & sustain . . . 22
8. Deliverables Summary — Google Workspace Security Baseline, DLP & Context-Aware Access (CAA) 22
Documents . . . 22
Scripts (`scripts/`) . . . 23
Named objects (reuse verbatim) . . . 23
Definition of done . . . 24
Effort tier . . . 24
Appendix A — PowerShell Scripts 25

Executive Summary — Google Workspace Security Baseline, DLP & Context-Aware Access (CAA)

The problem

A new or freshly-adopted Google Workspace tenant is **not secure by default at enterprise standard**. Out of the box, two-step verification is optional, web sessions are effectively indefinite, Drive and Gmail sharing is wide open, there is no Data Loss Prevention on sensitive content, and access is granted from **any device on any network**. Each of those defaults is a direct path to account takeover or data loss — and they persist silently until an incident exposes them.

The solution

This solution establishes a repeatable **Google Workspace security posture** in three reinforcing layers, deployed **pilot-first** and **rollback-ready**:

1. **Admin-console hardening baseline** — enforced 2-Step Verification (security key / passkey for

privileged accounts), bounded reauthentication sessions, tightened Drive/Gmail sharing, and closed legacy authentication surfaces.

1. **Data Loss Prevention (DLP)** — named rules that scan **Drive** and **Gmail** for sensitive

content (card numbers, national IDs, financial/health data, or custom detectors) and take a graded **audit** → **warn** → **block** action.

1. **Context-Aware Access (CAA)** — the Zero-Trust gate: access to apps is granted only from a

trusted context (corporate network, managed/encrypted device, allowed region), simulated in **monitor mode** before it is enforced.

Together they move the tenant from *implicit trust* to **explicit, contextual, data-aware trust** — verifying identity, device/context, and data on every access.

How it is delivered

The engagement follows a disciplined **Assess** → **Configure** → **Pilot** → **Validate** → **Expand** model with explicit pass/fail gates and a documented rollback for every production change. Every control is proven on a curated **pilot organizational unit** before it touches the fleet, then rolled out OU by OU. Five PowerShell scripts (read-only discovery, validation, and reporting; safe default-`--WhatIf` remediation and scope targeting) make the posture measurable and repeatable.

Business outcome

- **Reduced account-takeover risk** — enforced phishing-resistant 2SV and bounded sessions.
- **Reduced data-loss risk** — DLP prevents sensitive content from being over-shared or emailed out,

even by legitimately authenticated users.

- **Zero-Trust access** — CAA ensures corporate data opens only from trusted devices and networks.

• **Provable, auditable posture** — validation and coverage reporting show exactly what is enforced, where, and which exceptions are tracked.

Scope note

The hardening baseline applies to **every** Workspace edition. **DLP for Drive/Gmail rule authoring and Context-Aware Access are edition-gated** (Enterprise / Education tiers) and are flagged as such — confirm your licensing covers the layers you intend to enforce.

Bottom line: a Google Workspace tenant hardened to enterprise standard — baseline, DLP, and Context-Aware Access enforcing Zero-Trust — proven on a pilot before you scale.

1. Solution Overview — Google Workspace Security Baseline, DLP & Context-Aware Access (CAA)

A new or freshly-adopted Google Workspace tenant is **not secure by default at enterprise standard**. The out-of-the-box posture leaves two-step verification optional, sessions long-lived, Drive/Gmail sharing wide open, no Data Loss Prevention (DLP) on sensitive content, and access granted from any device on any network. This solution closes that gap by establishing a repeatable **Google Workspace security posture** built from three reinforcing layers, deployed **pilot-first** and **rollback-ready**.

> ***Vendor boundary.*** *Google* ***Admin console*** *(admin.google.com) paths and settings are authored at click-by-click detail from Google's current public documentation. Feature availability is* ***edition-gated*** *— several controls (Context-Aware Access, and the full DLP for Drive/Gmail rule engine) require* ***Enterprise / Education Plus / Enterprise Plus*** *tiers — and those gates are flagged where they apply. Where a page or toggle is evolving, it is flagged* ***"verify in your tenant."***

The Workspace security model — three layers, one posture

Layer 1 — Admin-console hardening baseline (identity & session hygiene)

The foundation is a **named, documented baseline** of admin-console settings applied to the organization:

• **2-Step Verification (2SV)** enforced (phone prompt → security key / passkey for privileged accounts), with a **new-user enrollment grace period** so onboarding is not broken.

• **Google session control** set to a bounded reauthentication window (e.g. 8–12 hours web session) instead of indefinite sessions that let a stolen cookie bypass 2SV forever.

• **Sharing settings** for Drive & Docs tightened: external sharing constrained, "anyone with the link" curtailed, warnings on outside-domain sharing.

• **Less-secure surfaces closed**: legacy/basic-auth protocols, unrestricted third-party app access (OAuth app allow-listing), and super-admin count minimized.

This layer is **edition-independent** — every Workspace tenant should have it.

Layer 2 — Data Loss Prevention (DLP) for Drive & Gmail

Baseline hygiene stops account takeover; **DLP stops the data itself from leaking**. Using the Admin console **Data protection** engine, named rules scan **Drive** files and **Gmail** messages for sensitive content (credit-card numbers, national IDs, health/financial data, or custom word-list / regex detectors) and take a graded **action** — **audit** → **warn** → **block** — when a rule matches. DLP for Drive/Gmail rule authoring is an **Enterprise-tier** capability (see Requirements).

Layer 3 — Context-Aware Access (CAA) — the Zero-Trust gate

Even a hardened, DLP-protected tenant grants access from **any device, any network** by default. **Context-Aware Access** adds the Zero-Trust gate: **access levels** define the *context* required to reach an app — corporate IP range, an encrypted / screen-locked / company-owned device, a minimum OS, an allowed region — and **assignments** bind those levels to apps (Drive, Gmail, Admin console) per organizational unit or group. CAA requires an **Enterprise / Education** edition and works best with **monitor mode** first (simulate before enforce). This is what turns "correct password + 2SV" into "correct password + 2SV **from a trusted context**."

How the three layers enforce Zero-Trust

Zero-Trust means *never trust, always verify* on **identity**, **device/context**, and **data**:

- **Identity** is verified by the hardening baseline (2SV, bounded sessions, minimized admins).
- **Device & context** are verified by CAA access levels (trusted network / managed, encrypted device / allowed region) before an app will open.
- **Data** is protected by DLP regardless of who the user is — sensitive content cannot be over-shared or emailed out even by a legitimately-authenticated user.

Together they move the tenant from *implicit trust* to *explicit, contextual, data-aware trust*.

Deployment model — Assess → Configure → Pilot → Validate → Expand

Every change follows the category-standard staged model with explicit gates and a documented rollback (mandatory for production changes):

1. **Assess** — discover current posture (2SV coverage, session length, sharing exposure, DLP/CAA presence) with `GWSEC-Discovery.ps1`; identify the risky defaults.
1. **Configure** — apply the named hardening baseline, author DLP rules in **audit** mode, and create CAA access levels in **monitor** mode — scoped to a **pilot OU**, not the whole org.
1. **Pilot** — enable on the pilot OU (e.g. `Security Baseline - Pilot`); confirm no legitimate work is broken. **Gate:** baseline applied, DLP fires on test content, CAA gates as designed.
1. **Validate** — run `GWSEC-Validation.ps1` per OU and `GWSEC-Report.ps1` for coverage/exceptions; promote DLP audit→block and CAA monitor→enforce only after clean results.
1. **Expand** — roll out OU-by-OU to the fleet, keeping the rollback (re-widen sharing, drop session enforcement, set DLP/CAA back to audit/monitor) documented at every step.

What this solution delivers

- The **Solution Overview** (this document) — the Workspace security model.
- A **Requirements Guide** — edition, super-admin, identity/context signals, and pilot OU, each with verify / implement-if-missing.
- An **Implementation Guide** — the exact, named hardening baseline; DLP rules for Drive/Gmail; CAA access levels + assignments; pilot then expand.
- **5 PowerShell scripts** — security-posture discovery, per-OU baseline/DLP/CAA validation, a posture coverage/exception report, safe (default `-WhatIf`) remediation, and a pilot-scope helper.
- **Testing, Troubleshooting, and Best-Practices** guides plus a deliverables summary.

Bottom line: a Google Workspace tenant hardened to enterprise standard — baseline, DLP, and Context-Aware Access enforcing Zero-Trust — proven on a pilot before you scale.

2. Requirements Guide — Google Workspace Security Baseline, DLP & Context-Aware Access (CAA)

Verify **every** requirement before configuring. Each entry: **Description · Why · Verify · Implement-if-missing.** Category-wide prerequisites are in `global-requirements-google.md`.

> ***Vendor boundary.*** *Admin console paths are authored from Google's current public documentation.* ***DLP for Drive/Gmail rule authoring and Context-Aware Access are edition-gated*** *(Enterprise / Education tiers) — confirm the exact editions and toggles that apply to *your* licensing. Anything not confirmed GA in your tenant is flagged* ***"verify in your tenant."***

2.1 A Workspace edition that supports the controls you will enforce

Description: A Google Workspace (or Cloud Identity) edition whose feature set covers the layers you intend to enforce. The **hardening baseline** (2SV, session control, sharing) works on **all** editions. **Context-Aware Access** and the **DLP for Drive/Gmail rule engine** require higher tiers — typically **Enterprise Standard/Plus**, **Education Standard/Plus**, **Enterprise Essentials Plus**, or **Cloud Identity Premium** (for CAA). **Why:** Authoring DLP rules and CAA access levels on an edition that lacks them will fail at the console — you must know before you plan the pilot which layers your license supports. **Verify:** Admin console (`https://admin.google.com`) → **Billing** → **Subscriptions**; confirm the edition and license counts. Then confirm the surfaces exist: **Security** → **Access and data control** → **Data protection** (DLP) and **Security** → **Access and data control** → **Context-Aware Access**. *(Feature availability is edition-gated — verify in your tenant.)* **Implement:** Acquire the required edition through Google or an authorized reseller. If CAA/DLP are out of scope for now, deploy **Layer 1 (hardening baseline)** alone and document the deferred layers.

2.2 Super-admin (and least-privilege operator roles)

Description: A **super-admin** account to set org-wide security toggles, plus scoped admin roles so day-to-day work is least-privilege: **Security Settings** / **Services** (2SV, session, CAA), **Data protection**

(DLP) admin, and **Drive and Docs** settings. **Why:** 2SV enforcement, session control, CAA, and DLP publishing require elevated rights; reserve super-admin for tenant-wide toggles and delegate the rest. **Verify:** Admin console → **Account** → **Admin roles**; confirm the operator holds Security, Data protection, and Drive/Docs privileges, and that super-admins are few and 2SV-enrolled. **Implement:** Assign least-privilege admin roles per surface; enroll every super-admin in 2SV (ideally security key / passkey) **before** enforcing 2SV org-wide (see 2.3).

2.3 2SV readiness (enrollment path + break-glass)

Description: A path for users to enroll a second factor, a decided **enforcement method** (any 2SV, or **security-key/passkey-only** for privileged accounts), a **new-user enrollment grace period**, and **backup / break-glass** codes so enforcement does not lock anyone out. **Why:** Enforcing 2SV before users have enrolled — or without break-glass — causes lockouts; the grace period and backup codes are the safety net. **Verify:** Admin console → **Security** → **Authentication** → **2-step verification**; confirm allowed methods, and that a super-admin has generated **backup codes** and holds a break-glass account. **Implement:** Publish enrollment instructions, generate backup codes for admins, set the new-user enrollment period, then enforce on the pilot OU first (Implementation Step 2).

2.4 Identity & session signals

Description: A defined **session policy** target (reauthentication window, e.g. 8–12h web) and awareness of which sessions the setting governs (Google web session; native/mobile apps behave differently). **Why:** Indefinite sessions let a stolen cookie bypass 2SV; the session-control setting is a core baseline lever, but it must be set at a value that does not cripple legitimate long-running work. **Verify:** Admin console → **Security** → **Access and data control** → **Google session control**; confirm the current web-session length and reauthentication policy. **Implement:** Decide the target window with the security stakeholder; apply to the pilot OU first.

2.5 Context signals for CAA (network + device)

Description: The **context signals** CAA will gate on: known **corporate IP ranges** (CIDR), **device** posture (encrypted, screen-lock, company-owned, minimum OS) via **endpoint verification / device management** where required, and allowed **regions**. **Why:** A CAA access level is only as good as its signals — you must know your egress IP ranges and have device signals flowing before an access level can meaningfully require them. Device-attribute levels depend on managed/endpoint-verified devices. **Verify:** Confirm your corporate egress CIDR blocks; Admin console → **Devices** shows enrolled / endpoint-verified devices for the pilot users. *(Device-signal availability depends on management posture — verify in your tenant.)* **Implement:** Catalog corporate IP ranges; roll out endpoint verification / device management to the pilot users so device attributes are available before you require them in an access level.

2.6 DLP scope & detectors (what "sensitive" means here)

Description: A decided **DLP scope**: which content types are sensitive (predefined detectors — credit-card, SSN/national ID, financial/health — or **custom word-list / regex detectors**), which surfaces (**Drive**, **Gmail**, and which triggers: external sharing, message send), and the graded **action** ladder (audit → warn → block). **Why:** DLP rules are only meaningful against defined sensitive-data classes and a decided enforcement posture; starting at **block** without an audit phase breaks legitimate workflows. **Verify:** The data-governance owner has confirmed the sensitive-data classes and the surfaces in scope;

Admin console → **Security** → **Access and data control** → **Data protection** loads. **Implement:** Document the detector list and the audit→warn→block plan (Implementation Steps 4–5); build any custom detectors before authoring rules.

2.7 Pilot scope (OU) and named baseline objects

Description: A **pilot organizational unit** (e.g. `Security Baseline - Pilot`) to validate on before fleet rollout, and the **named** baseline objects this solution reuses: the pilot OU, the CAA access levels (`Access - Corp Network`, `Access - Managed Device`), and the DLP rules (`DLP - Drive - Sensitive - External`, `DLP - Gmail - Sensitive - Outbound`). **Why:** Every solution follows **Assess** → **Configure** → **Pilot** → **Validate** → **Expand**; a curated pilot OU proves the design, and consistent object names make validation, reporting, and rollback repeatable. **Verify:** Admin console → **Directory** → **Organizational units** shows the pilot OU (or run `GWSEC-Set-ScopeTargeting.ps1`). **Implement:** Create the pilot OU with `GWSEC-Set-ScopeTargeting.ps1` (or **Directory** → **Organizational units** → **Create**) and move a few representative users into it.

2.8 Security stakeholders + change control / rollback

Description: Engagement with **security (CISO)** and **data-governance / legal** stakeholders whose policies the baseline, DLP, and CAA must satisfy, and a documented **change-control** process with a **rollback** for every production change (session enforcement, sharing tightening, DLP block, CAA enforce). **Why:** Tightening sessions/sharing, enforcing DLP block, or enforcing CAA can block legitimate work or lock users out; a pilot gate, change window, and rollback are mandatory (global requirement 6). **Verify:** Applicable policies and named approvers are confirmed; a change ticket exists with an approver, a maintenance window, and a rollback step. **Implement:** Identify security/governance owners, obtain the policy requirements, and record the rollback (re-widen sharing, relax session, set DLP back to audit, set CAA back to monitor) before production.

Checklist

- Edition supports the layers in scope (baseline = all; DLP rules + CAA = Enterprise/Education tiers — verify in your tenant)
- Super-admin available; least-privilege operator roles (Security, Data protection, Drive/Docs) assigned
- 2SV enrollment path, method decided, new-user grace period, and admin backup/break-glass codes ready
- Session policy target decided (e.g. 8–12h web reauthentication)
- CAA context signals ready — corporate CIDR ranges cataloged; device signals flowing for pilot users
- DLP scope decided — detectors, surfaces (Drive/Gmail), audit→warn→block ladder
- `Security Baseline - Pilot` OU created; named baseline/DLP/CAA objects agreed
- Security & data-governance engaged; change control / rollback documented

Global Requirements — Google Workspace & Gemini Solutions

These requirements apply to **every** solution in the **Google** category. They are the common foundation each Google Workspace / Gemini solution assumes is already in place (or stands up as part of its own Requirements section). Verify each before starting a solution's implementation steps.

> ***Vendor boundary (applies to every Google solution).*** *The **Google Admin console** (admin.google.com), **Google Cloud / Cloud Identity**, and the **Microsoft / Entra** sides are authored at exact, current click-by-click detail from the vendors' public documentation. **Gemini Enterprise** capabilities that are in preview or rolling out are **cited or flagged "verify in your tenant"** — never invented. **Third-party migration tools** (e.g. for mail/Drive/Chat data movement) and **third-party enterprise apps** (ServiceNow, SAP, Databricks, etc.) are integrated at the pattern/architectural level; their internal console steps are deferred to the vendor's own docs.*

1. Google Workspace / Cloud Identity tenant

• **Description:** A provisioned Google Workspace (or Cloud Identity) tenant with a **super-admin** account for configuration, and the appropriate Workspace edition/licensing for the capability in scope (e.g. Enterprise Plus for Vault/CAA/DLP, Gemini/AI add-on where required).

• **Why required:** All configuration, policy, and API work is performed against this tenant.

• **How to verify:** Sign in to **admin.google.com** as a super-admin; confirm edition and license counts under **Billing / Subscriptions**.

• **How to implement if missing:** Provision the tenant and licenses through Google or an authorized reseller before starting.

2. Source Microsoft 365 / Entra environment (for migration & coexistence)

• **Description:** For migration/coexistence/identity solutions, administrative access to the source **Microsoft 365** tenant and **Microsoft Entra ID** (Global Administrator or the least-privilege roles the solution names).

• **Why required:** Migration, directory sync, SSO federation, and coexistence read from and change the Microsoft side.

• **How to verify:** Confirm access to the M365 admin center and the Entra admin center with the required role.

• **How to implement if missing:** Obtain the role from the M365/Entra tenant owner.

3. DNS control for the routed domains

• **Description:** Ability to create/modify **DNS records** (MX, SPF, DKIM, DMARC, TXT, CNAME) for the domains being migrated, coexisting, or verified.

• **Why required:** Domain verification, mail routing/coexistence, and authentication all depend on DNS changes.

• **How to verify:** Confirm access to the authoritative DNS zone for each domain.

• **How to implement if missing:** Coordinate with whoever controls DNS; stage changes under change control (mail-flow changes are high-impact).

4. Identity & provisioning source of truth

• **Description:** A defined **identity source of truth** (on-prem AD, Entra ID, or an HR/IGA system) and the sync mechanism (e.g. **Google Cloud Directory Sync (GCDS)** or SCIM-based provisioning).

• **Why required:** Consistent users/groups across ecosystems underpin SSO, licensing, and access.

• **How to verify:** Confirm which directory is authoritative and how objects flow into Google.

• **How to implement if missing:** Define the source of truth and provisioning model before configuring SSO or migrating.

5. A pilot scope (OU / group) and change control

• **Description:** A **pilot organizational unit or group** to validate on before fleet-wide rollout, and a **change-control** process for production changes (especially mail flow, DNS, identity, and DLP).

• **Why required:** Every solution follows an **Assess** → **Configure** → **Pilot** → **Validate** → **Expand** model; the pilot proves the design and change control protects production.

• **How to verify:** Confirm a named pilot OU/group exists and a change window/approval path is available.

• **How to implement if missing:** Create a pilot OU/group and agree the change-control process with the owners before making production changes.

6. Security, compliance & governance stakeholders

• **Description:** Engagement with the **security (CISO), legal/eDiscovery, and data-governance** stakeholders whose policies the configuration must satisfy (DLP, retention, Vault/Purview, and any regulatory regime such as ITAR/DFARS/Assured Controls where applicable).

• **Why required:** Data governance, eDiscovery, DLP, and regulated-workload settings must align to enterprise policy and legal requirements, not just technical defaults.

• **How to verify:** Confirm the applicable policies and named stakeholders/approvers.

• **How to implement if missing:** Identify the owners and obtain the policy/compliance requirements before configuring governance controls.

*The deployment model across every Google solution is the same: **Assess** → **Configure** → **Pilot** → **Validate** → **Expand**, with explicit pass/fail gates and a documented rollback for production changes.*

3. Implementation Guide — Google Workspace Security Baseline, DLP & Context-Aware Access (CAA)

This guide applies the **named security posture** in the category-standard order **Assess** → **Configure** → **Pilot** → **Validate** → **Expand**, scoped to a **pilot OU first**, with a documented rollback at every gate. All paths are in the **Google Admin console** (`https://admin.google.com`).

> ***Vendor boundary.*** *Console paths follow Google's current public documentation.* ***CAA*** *and the* ***DLP for Drive/Gmail rule engine*** *are* ***edition-gated*** *(Enterprise / Education tiers). Where a page or toggle is evolving, it is flagged* ***"verify in your tenant."*** *Never enforce (session, DLP block, CAA enforce) org-wide before the pilot gate passes.*

Named objects this solution creates and reuses

Object	Name (reuse verbatim)	Purpose
Pilot OU	`Security Baseline - Pilot`	Curated scope validated before fleet rollout
CAA access level	`Access - Corp Network`	Require a known corporate IP range
CAA access level	`Access - Managed Device`	Require encrypted + screen-locked (+ company-owned) device
DLP rule (Drive)	`DLP - Drive - Sensitive - External`	Scan Drive files for sensitive data on external sharing
DLP rule (Gmail)	`DLP - Gmail - Sensitive - Outbound`	Scan outbound Gmail for sensitive data

Step 0 — Assess current posture (read-only)

Before changing anything, capture the baseline you are improving from.

• Run `GWSEC-Discovery.ps1` — reports 2SV method availability, session-control posture, Drive external-sharing settings, and whether any DLP rules / CAA access levels already exist.

• Cross-check in the Admin console: **Security** → **Security dashboard** and **Reporting → Audit and investigation** for current sharing / login patterns.

• Record the pre-change values (they are your **rollback targets**).

Gate: you have a written snapshot of the starting posture and the risky defaults to fix.

Step 1 — Create the pilot OU and move representative users

• Admin console → **Directory** → **Organizational units** → **Create organizational unit** → name it `Security Baseline - Pilot` (or run `GWSEC-Set-ScopeTargeting.ps1 -Apply`).

• Move 3–10 representative users (a super-admin's own test account, one power user, one field/mobile user) into the pilot OU so every scenario is covered.

Gate: the pilot OU exists and contains representative users.

Step 2 — Apply the hardening baseline (Layer 1) to the pilot OU

Apply each setting **scoped to** `Security Baseline - Pilot` (select the OU in the left pane of each settings page), not the root OU.

2a. 2-Step Verification (2SV). Admin console → **Security** → **Authentication** → **2-step verification**.

• First confirm every super-admin has enrolled and holds **backup codes** (Security → Authentication → generate backup codes) — this is break-glass.

• Set **Allow users to turn on 2-Step Verification = On**, **Enforcement = On** for the pilot OU, choose the method (**Any**, or **Only security key** including passkeys for privileged users), and set a **New user enrollment period** so onboarding is not broken.

2b. Google session control. Admin console → **Security** → **Access and data control** → **Google session control**. Set the **web session duration** to the agreed window (e.g. **8 hours** to **14 hours**) so a stolen cookie cannot bypass 2SV indefinitely; require reauthentication (password / security key) on expiry.

2c. Drive & Docs sharing. Admin console → **Apps** → **Google Workspace** → **Drive and Docs** → **Sharing settings** (scoped to the pilot OU).

• Constrain **external sharing** (e.g. allowlisted domains only, or off), disable/limit **"anyone with the link"**, **enable** warn when sharing outside the organization**, and set the default link scope to** restricted**.

2d. Close less-secure surfaces. Admin console → **Security** → **Access and data control** → **Less secure apps / API controls** → **App access control** — restrict/allow-list third-party OAuth apps; confirm legacy/basic-auth access is off. Keep the **super-admin count minimal**.

Use `GWSEC-Remediation.ps1` (default `-WhatIf`) to preview any scriptable baseline fixes (e.g. tightening a broadly-shared file surfaced in Step 0) before applying with `-Apply`.

Gate: the pilot OU shows 2SV enforced, a bounded session, restricted sharing, and closed legacy surfaces — and no pilot user's legitimate work is broken.

Step 3 — Create CAA access levels (Layer 3, monitor mode) — *edition-gated*

Admin console → **Security** → **Access and data control** → **Context-Aware Access**. Turn CAA **On** for the org if not already, then **Access levels** → **Create access level** (Basic mode).

3a. `Access - Corp Network`**.** Attribute → **IP subnet** → enter your corporate egress ranges in **CIDR** (IPv4/IPv6). Condition = **Meet attributes**. Save.

3b. `Access - Managed Device`**.** Attributes → **Device policy**: **Encrypted = Encrypted**, **Screen lock = required**, optionally **Company-owned = required**, and a **minimum OS version**. Combine with AND logic. Save. *(Device attributes require endpoint verification / device management signals — verify in your tenant.)*

Access levels do nothing until assigned. Create them now; assign in Step 6.

Gate: both access levels exist with correct signals; nothing is assigned/enforced yet.

Step 4 — Author DLP rules (Layer 2, audit mode) — *edition-gated*

Admin console → **Security** → **Access and data control** → **Data protection**. If needed, build custom detectors first via **Manage detectors** → **Add detector** → **Word list / Regular expression**.

4a. `DLP - Drive - Sensitive - External`**. Create rule** → **Drive**.

- **Scope:** the pilot OU (`Security Baseline - Pilot`).
- **Trigger:** *File shared outside the organization* (and *"anyone with the link"*).
- **Conditions:** predefined detectors (credit-card number, national ID, financial/health) and/or

your custom detector, with a threshold (e.g. likelihood = *Possible* and count ≥ 1).

- **Action (start at audit): Audit only / log the event** (no block yet). Save + activate.

4b. `DLP - Gmail - Sensitive - Outbound`**. Create rule** → **Gmail**.

- **Scope:** the pilot OU. **Trigger:** *Message sent* (outbound / external recipients).
- **Conditions:** the same detector set applied to subject/body/attachments.
- **Action (start at audit): Audit only** (later: *Warn* / *Quarantine* / *Block delivery*).

Save + activate.

Gate: both rules are active in **audit** mode and generating incidents you can review — no user is blocked yet.

Step 5 — Pilot: exercise the controls on the pilot OU

- **Baseline:** confirm pilot users are prompted for 2SV, sessions expire and reauthenticate,

external-sharing warnings appear, and legacy clients are refused.

- **DLP:** from a pilot account, attempt to externally share a Drive test file containing a

synthetic credit-card / national-ID string, and send an outbound test email with the same → confirm **audit incidents** appear in **Data protection** / the security investigation tool.

- **CAA (still monitor):** review Step 6 assignment behavior below.

Run `GWSEC-Validation.ps1 -OrgUnitPath '/Security Baseline - Pilot'` to check the pilot OU against the intended baseline / DLP / CAA state, and `GWSEC-Report.ps1` for a coverage /

exceptions view.

Gate: baseline applied, DLP fires on test content (audit), CAA levels ready — with **no false-positive breakage** of legitimate pilot work.

Step 6 — Assign CAA (monitor → enforce) and graduate DLP (audit → block)

6a. Assign CAA in monitor mode. Context-Aware Access → **Assign access levels** → select apps (**Drive**, **Gmail**, and the **Admin console** for privileged OUs) → assign `Access - Corp Network` and/or `Access - Managed Device` to the **pilot OU**. New assignments default to **monitor mode** — this **simulates** enforcement (logs what *would* be blocked) without blocking users. Review the would-block signals for false positives. **6b. Enforce CAA.** Once monitor logs are clean, switch the assignment from **monitor** to **enforce** for the pilot OU. **6c. Graduate DLP.** Once audit incidents confirm the rules match the right content without noise, raise the action ladder: `DLP - Gmail - Sensitive - Outbound` → **Warn** then **Block delivery**; `DLP - Drive - Sensitive - External` → **Block external sharing**.

Gate: CAA enforced and DLP at block on the pilot OU, still with no legitimate-work breakage. Re-run `GWSEC-Validation.ps1` — it should pass.

Step 7 — Expand to the fleet, OU by OU

With the pilot validated:

- Apply the **hardening baseline** (Step 2) OU-by-OU, then **assign CAA** (monitor → enforce) and **scope DLP** rules to each OU, promoting audit→block per OU as each clears.
- After each wave, run `GWSEC-Validation.ps1` for the OU and `GWSEC-Report.ps1` for fleet-wide coverage and exceptions.
- Keep the **rollback** documented and tested at every wave.

Gate: every in-scope OU passes validation; the coverage report shows the baseline, DLP, and CAA applied with exceptions explicitly tracked.

Rollback (keep ready at every gate)

- **Session/2SV:** relax the session window / lift 2SV enforcement for the affected OU.
- **Sharing:** re-widen the sharing setting to the previous value recorded in Step 0.
- **DLP:** set the rule action back to **Audit only** (or deactivate the rule).
- **CAA:** set the assignment back to **monitor mode** (or unassign the access level).

Each is a single scoped change in the Admin console; record the pre-change value in Step 0 so rollback is exact.

5. Testing & Validation — Google Workspace Security Baseline, DLP & Context-Aware Access (CAA)

Test **on the pilot OU (**`Security Baseline - Pilot`**) first**, using synthetic test data only. Each test states what to do, the **expected (pass)** result, and the **fail** signal. Re-run after every promotion (audit→block, monitor→enforce) and after each expansion wave.

> *Use **synthetic** sensitive values for DLP tests (e.g. the standard* `4111 1111 1111 1111` *test card number, a fake national-ID pattern). Never test with real regulated data.*

A. Hardening baseline (Layer 1)

#	Test	Pass	Fail
A1	Sign in as a pilot user	Prompted for 2SV (phone prompt / security key / passkey)	No second factor requested — enforcement not applied to the OU
A2	Leave a web session idle past the configured window	Reauthentication (password / key) required on return	Session persists indefinitely — session control not set for the OU
A3	Share a Drive doc to an outside-domain address	Warning shown / sharing constrained per policy	Silent external share with no warning — sharing setting not applied
A4	Attempt legacy/basic-auth mail client sign-in	Refused	Legacy client connects — less-secure surface still open
A5	Count super-admins (Admin roles)	Minimal, all 2SV-enrolled with backup codes	Excess or un-enrolled super-admins

Run `GWSEC-Validation.ps1 -OrgUnitPath '/Security Baseline - Pilot'` — baseline checks report **PASS** for the OU.

B. DLP for Drive & Gmail (Layer 2) — *edition-gated*

#	Test	Pass	Fail
B1	(Audit phase) Externally share a Drive file containing a synthetic card/ID string	Incident logged in **Data protection** / security investigation tool; share allowed	No incident — rule scope/detector/trigger wrong
B2	(Audit phase) Send outbound Gmail with the same synthetic string	Incident logged	No incident — Gmail rule not matching

#	Test	Pass	Fail
B3	(Block phase) Repeat B1 after graduating to **Block external sharing**	External share **blocked** with user notice	Share still succeeds — action not promoted / OU not in scope
B4	(Block phase) Repeat B2 after **Block delivery / Quarantine**	Message blocked / quarantined	Message delivered — action not promoted
B5	Negative test — share/send a benign file with no sensitive data	No incident, no block (no false positive)	Benign content blocked — detector too broad, tune threshold

C. Context-Aware Access (Layer 3) — *edition-gated*

#	Test	Pass	Fail
C1	(Monitor phase) Access Drive/Gmail from **off-network / non-compliant** context	Access allowed but **would-block** logged in monitor	Nothing logged — access level not assigned / signals missing
C2	(Enforce phase) Access from a **compliant** context (corp IP / managed device)	Access granted	Compliant user blocked — access-level signal wrong (IP range, device attribute)
C3	(Enforce phase) Access from a **non-compliant** context	Access **blocked** by CAA	Access granted — assignment still in monitor, not enforce
C4	Admin-console access from off-network (privileged OU)	Blocked per `Access - Corp Network` assignment	Admin console reachable off-network

Run `GWSEC-Validation.ps1` — CAA assignment state (monitor vs enforce) and access-level presence report as expected for the OU.

D. Coverage & exceptions (fleet)

• Run `GWSEC-Report.ps1` — confirm the coverage view shows the baseline, DLP rules, and CAA assignments applied to each in-scope OU, with any exceptions explicitly listed and owned.

• Confirm the **rollback** for each control has been rehearsed at least once on the pilot OU (relax session, re-widen sharing, DLP→audit, CAA→monitor) and returns the OU to the pre-change state.

Exit criteria (before expanding past the pilot)

• All Section A tests **PASS** on the pilot OU.

• DLP fires in audit **and** blocks after promotion (B1–B4), with no false positives (B5).

- CAA logs in monitor, grants compliant and blocks non-compliant after enforce (C1–C4).
- `GWSEC-Validation.ps1` passes for the pilot OU and `GWSEC-Report.ps1` shows clean coverage.
- Rollback verified. Only then proceed to Implementation Step 7 (expand).

6. Troubleshooting — Google Workspace Security Baseline, DLP & Context-Aware Access (CAA)

Symptom → likely cause → fix, for the common issues across the three layers. Work on the **pilot OU first**, and remember every enforcement has a **rollback** (relax session, re-widen sharing, DLP→audit, CAA→monitor). Edition-gated notes are flagged **"verify in your tenant."**

Hardening baseline (Layer 1)

Users not prompted for 2SV after enforcement.

- *Cause:* enforcement scoped to the wrong OU, or users still inside the **new-user enrollment

grace period**; or they never enrolled a factor.

- *Fix:* Admin console → **Security** → **Authentication** → **2-step verification**; confirm the setting is

scoped to the intended OU and the grace period has elapsed; verify enrollment in the user's security settings.

Admins locked out after enforcing 2SV.

- *Cause:* super-admin enrolled no factor / has no backup codes before enforcement.
- *Fix:* use the **break-glass** super-admin and pre-generated **backup codes**; if none exist,

another super-admin generates backup codes (Security → Authentication) for the affected admin. *Always enroll admins and generate backup codes before org-wide enforcement.*

Sessions never expire / users are never asked to reauthenticate.

- *Cause:* Google session control not set for the OU, or the value governs only the web session

while the complaint is about a native/mobile app (which behaves differently).

- *Fix:* **Security** → **Access and data control** → **Google session control**; set the web-session

duration for the OU. Note native-app session behavior differs — verify in your tenant.

External sharing still silent / "anyone with the link" still available.

- *Cause:* sharing settings scoped to the root OU but not the target OU, or child OU inheriting a

looser override.

- *Fix:* **Apps** → **Google Workspace** → **Drive and Docs** → **Sharing settings** scoped to the OU; disable

anyone-with-link, enable outside-org warnings, set default link scope to restricted.

Legacy mail client still connects.

- *Cause:* less-secure-app / legacy-auth access still permitted, or an app-password in use.

- *Fix:* **Security** → **Access and data control** → restrict legacy/basic-auth; review app passwords.

Data Loss Prevention (Layer 2) — *edition-gated*

DLP rule fires no incidents even on obvious test content.

- *Cause:* rule scoped to the wrong OU, trigger mismatch (e.g. rule triggers on *external* share but the test was internal), detector/threshold too strict, or the rule is inactive.
- *Fix:* **Security** → **Access and data control** → **Data protection**; confirm the rule is **active**, scoped to the pilot OU, the **trigger** matches the test action, and the **detector likelihood / minimum count** are not set too high. Test with the standard synthetic values.

DLP blocks legitimate, benign content (false positives).

- *Cause:* detector too broad or threshold too low (single incidental match fires).
- *Fix:* raise detector **likelihood** and **minimum count**, narrow a custom word-list/regex detector, and re-run in **audit** before returning to block.

DLP "block" doesn't block — content still shares/sends.

- *Cause:* rule still in **Audit only**, or scoped to an OU the user is not in.
- *Fix:* promote the action to **Block external sharing** (Drive) / **Block delivery / Quarantine** (Gmail) and confirm OU scope.

Custom detector not matching expected data.

- *Cause:* regex/word-list error, or data format differs from the pattern.
- *Fix:* **Manage detectors**; correct the regex/word list and re-test with representative synthetic samples.

Context-Aware Access (Layer 3) — *edition-gated*

Compliant users blocked by CAA.

- *Cause:* access-level signal wrong — corporate **CIDR range** missing/incorrect, or a required **device attribute** (encryption / screen lock / company-owned) not flowing because endpoint verification / device management isn't deployed to those users.
- *Fix:* **Security** → **Access and data control** → **Context-Aware Access** → **Access levels**; correct the IP ranges; confirm device signals in **Devices**. Roll device signals out **before** requiring them. Verify in your tenant.

Non-compliant users are NOT blocked (enforcement not taking effect).

- *Cause:* the assignment is still in **monitor mode** (simulate only), or the access level isn't assigned to that app/OU.
- *Fix:* **Assign access levels**; switch the assignment from **monitor** to **enforce** for the OU

and confirm it is bound to the app (Drive/Gmail/Admin console).

Access works in the browser but not in a native/mobile app (or vice-versa).

- *Cause:* CAA behaves differently for non-web clients; some signals aren't available to native apps.
- *Fix:* test each client path explicitly; adjust the access level or app assignment; verify the

specific client's supported signals in your tenant.

Admin console reachable from off-network despite a corp-network level.

- *Cause:* the access level was assigned to apps but **not to the Admin console** for that OU.
- *Fix:* **Assign access levels** → include the **Admin console** assignment for the privileged OU.

Scripts

A `GWSEC-*` script errors on the API call / returns nothing.

- *Cause:* missing or expired OAuth token, insufficient scope, or wrong OU path.
- *Fix:* set `GOOGLE_OAUTH_TOKEN` to a valid super-admin access token with the read-only scopes each

script's header lists; pass the exact OU path (e.g. `/Security Baseline - Pilot`). Discovery / Validation / Report are read-only; Remediation and Set-ScopeTargeting default to `-WhatIf` — pass `-Apply` only after previewing.

Not sure whether an edition-gated feature exists in your tenant.

- *Fix:* **Billing** → **Subscriptions** for the edition, then confirm the **Data protection** and

Context-Aware Access pages are present. If absent, the layer requires a higher tier — deploy the hardening baseline (edition-independent) and document the deferred layer.

7. Best Practices — Google Workspace Security Baseline, DLP & Context-Aware Access (CAA)

Field-tested practices for a **staged, low-breakage** rollout of the Workspace security posture. The theme throughout is **staged enforcement**: observe before you block, pilot before you fleet, and keep a tested rollback at every step.

Staged enforcement (the core discipline)

- **Audit** → **Warn** → **Block for DLP.** Never publish a DLP rule straight to *block*. Run in **audit**

long enough to see real incident volume, tune detectors/thresholds against false positives, add **warn** so users self-correct, then **block** only the classes that must never leave.

- **Monitor** → **Enforce for CAA.** New CAA assignments default to **monitor mode** — keep them there

until the would-block logs are clean, then flip to **enforce**. Monitor mode is your simulation; use it.

- **Pilot OU** → **fleet, OU by OU.** Prove every control on `Security Baseline - Pilot` before touching

a production OU, then expand in waves, validating each. Never apply a new enforcement to the root OU first.

Identity & session hygiene

• **Enroll admins before enforcing.** Every super-admin enrolls 2SV (prefer **security key / passkey**) and holds backup codes **before org-wide enforcement — and keep a break-glass** super-admin account documented and secured.

• **Use security-key/passkey-only for privileged accounts.** Phishing-resistant factors for the accounts that matter most; a **new-user enrollment grace period** keeps onboarding smooth.

• **Bound the session, don't cripple it.** Set the web-session window tight enough to matter (8–14h) but not so tight it disrupts legitimate long tasks; decide the value with security.

• **Minimize super-admins** and review admin-role assignments regularly.

Data protection (DLP)

• **Start from templates, then customize.** Use Google's built-in rule templates (financial, health, PII) as a baseline; add **custom word-list / regex detectors** only for your organization-specific data.

• **Tune thresholds to cut noise.** Combine detector *likelihood* and *minimum count* so a single incidental match doesn't fire; the negative test (benign content passes) is as important as the positive.

• **Cover both surfaces.** Author matched rules for **Drive** (external sharing / anyone-with-link) and **Gmail** (outbound send) — leaking is equally possible through either.

• **Review incidents, don't just collect them.** Assign an owner to triage DLP incidents in the security investigation tool; incidents are signal, not noise-to-ignore.

Context-Aware Access (CAA)

• **Signals before requirements.** Catalog corporate egress CIDR ranges and get device/endpoint signals flowing **before** an access level requires them — an access level with no signal blocks everyone.

• **Compose small, named levels.** Keep `Access - Corp Network` and `Access - Managed Device` as separate, reusable levels and combine per app, rather than one monolithic level.

• **Gate the Admin console.** Assign a strict access level to the **Admin console** for privileged OUs so admin actions require a trusted context — a high-value, low-friction win.

• **Mind non-web clients.** CAA behavior differs for native/mobile apps; test those paths explicitly before enforcing.

Change control & rollback

• **Record pre-change values (Step 0) as rollback targets** for every control before you change it.

• **One scoped change at a time** per OU, under a change window with an approver, so a regression is easy to isolate and reverse.

• **Rehearse rollback on the pilot** at least once (relax session, re-widen sharing, DLP→audit, CAA→monitor) so you know it works under pressure.

Operate & sustain

• **Re-validate on a schedule.** Run `GWSEC-Validation.ps1` and `GWSEC-Report.ps1` periodically —

posture drifts as OUs, users, and sharing change.

• **Track exceptions explicitly.** Any OU or user deliberately outside the baseline gets a named, owned exception with a review date — not a silent gap.

• **Verify edition-gated features in your tenant.** CAA and DLP-rule availability and exact toggles evolve; confirm against your license and Google's current documentation before relying on them.

8. Deliverables Summary — Google Workspace Security Baseline, DLP & Context-Aware Access (CAA)

Everything included in this solution and how the pieces fit together. Use this as the index and the definition of done.

Documents

Document	What it gives you
`01-solution-overview.md`	The Workspace security model — hardening baseline, DLP, CAA, and how the three layers enforce Zero-Trust.
`02-requirements.md`	Prerequisites with verify / implement-if-missing: edition supporting DLP/CAA, super-admin, 2SV/session/context signals, DLP scope, pilot OU, change control.
`03-implementation.md`	Click-by-click Admin-console steps: named hardening baseline (2SV, sessions, sharing); DLP rules for Drive/Gmail; CAA access levels + assignments; pilot then expand.
`05-testing.md`	Pass/fail tests per layer (baseline, DLP audit→block, CAA monitor→enforce) plus coverage and rollback checks.
`06-troubleshooting.md`	Symptom → cause → fix for the common baseline / DLP / CAA issues.

Document	What it gives you
`07-best-practices.md`	Staged-enforcement discipline, identity/session hygiene, DLP tuning, CAA composition, change control.
`executive-summary.md`	One-page business case and outcome for decision-makers.

Scripts (`scripts/`)

All scripts are **read-only where they read live systems**; the two that can change state default to `-WhatIf`. They use the Google Admin SDK / Reports / Drive APIs where scriptable, and consume Admin-console exports where a setting is not exposed by API.

Script	Type	What it does
`GWSEC-Discovery.ps1`	Read-only	Security-posture discovery: 2SV method availability, session-control posture, Drive external-sharing settings, and presence of DLP rules / CAA access levels.
`GWSEC-Validation.ps1`	Read-only	Per-OU validation of the baseline, DLP rule state, and CAA assignment state (monitor vs enforce) against the intended posture.
`GWSEC-Report.ps1`	Read-only	Fleet posture coverage / exceptions report across OUs — what is applied, what is missing, what is a tracked exception.
`GWSEC-Remediation.ps1`	**Default** `-WhatIf`	Safe remediation of scriptable findings (e.g. tighten a broadly-shared Drive item); previews by default, applies only with `-Apply`.
`GWSEC-Set-ScopeTargeting.ps1`	**Default** `-WhatIf`	Creates/reuses the `Security Baseline - Pilot` OU (idempotent) so baseline/DLP/CAA can be scoped consistently.

Named objects (reuse verbatim)

Object	Name
Pilot OU	`Security Baseline - Pilot`
CAA access level	`Access - Corp Network`

Object	Name
CAA access level	`Access - Managed Device`
DLP rule (Drive)	`DLP - Drive - Sensitive - External`
DLP rule (Gmail)	`DLP - Gmail - Sensitive - Outbound`

Definition of done

• Hardening baseline (2SV, bounded session, restricted sharing, closed legacy surfaces) applied and **validated** on `Security Baseline - Pilot`, then expanded OU-by-OU.

• DLP rules for **Drive** and **Gmail** authored, run through **audit** → **warn** → **block**, tested with synthetic data and negative tests. *(Edition-gated — verify in your tenant.)*

• CAA access levels created and assigned **monitor** → **enforce**, with the Admin console gated for privileged OUs. *(Edition-gated — verify in your tenant.)*

• `GWSEC-Validation.ps1` passes for every in-scope OU; `GWSEC-Report.ps1` shows clean coverage with exceptions tracked; rollback rehearsed.

Effort tier

T4 — Google Workspace security transformation: architecture/governance work with live-environment care. Deployed **pilot-first** with explicit gates and a documented rollback for every production change.

Appendix A — PowerShell Scripts

Included in the accompanying ZIP. Each script's header documents full usage.

GWSEC-Discovery.ps1

Purpose: Read-only assessment of the current Google Workspace security posture BEFORE any change: two-step verification (2SV) enrollment across users, Drive external-sharing exposure (public 'anyone with link' / domain-wide / external), the count of super-admins, and whether DLP rules / Context-Aware Access levels already exist. The output is your rollback baseline and the list of risky defaults to fix. Nothing is changed. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\GWSEC-Discovery.ps1 [-MaxUsers 500] [-MaxFiles 500] Requires a Google super-admin OAuth access token in the GOOGLE_OAUTH_TOKEN environment variable (obtain via 'gcloud auth print-access-token' or your OAuth flow) with READ-ONLY scopes: admin.directory.user.readonly, admin.directory.rolemanagement.readonly, and drive.metadata.readonly. DLP-rule and Context-Aware Access inventory that is not exposed by API is confirmed in the Admin console (Security > Access and data control) — the script prints where to look. EXPECTED RESULTS A posture summary: users without 2SV, Drive items shared public/domain-wide/externally, super-admin count, and a DLP/CAA presence note. PASS = 2SV broadly enrolled, no broad sharing, minimal super-admins. FAIL signals feed GWSEC-Remediation.ps1, GWSEC-Validation.ps1, and GWSEC-Report.ps1. Edition-gated (DLP-rule/CAA) state is verified in your tenant. .NOTES White-label — the repeatable way. Read-only where it reads live systems (Admin Directory & Drive metadata APIs). DLP-for-Drive/Gmail rule authoring and Context-Aware Access are edition-gated (Enterprise/Education tiers); their presence is confirmed in the Admin console. #> [CmdletBinding()] param([int]$MaxUsers = 500, [int]$MaxFiles = 500)

How to run: powershell -ExecutionPolicy Bypass -File .\GWSEC-Discovery.ps1 [-MaxUsers 500] [-MaxFiles 500] Requires a Google super-admin OAuth access token in the GOOGLE_OAUTH_TOKEN environment variable (obtain via 'gcloud auth print-access-token' or your OAuth flow) with READ-ONLY scopes: admin.directory.user.readonly, admin.directory.rolemanagement.readonly, and drive.metadata.readonly. DLP-rule and Context-Aware Access inventory that is not exposed by API is confirmed in the Admin console (Security > Access and data control) — the script prints where to look. EXPECTED RESULTS A posture summary: users without 2SV, Drive items shared public/domain-wide/externally, super-admin count, and a DLP/CAA presence note. PASS = 2SV broadly enrolled, no broad sharing, minimal super-admins. FAIL signals feed GWSEC-Remediation.ps1, GWSEC-Validation.ps1, and GWSEC-Report.ps1. Edition-gated (DLP-rule/CAA) state is verified in your tenant. .NOTES White-label — the repeatable way. Read-only where it reads live systems (Admin Directory & Drive metadata APIs). DLP-for-Drive/Gmail rule authoring and Context-Aware Access are edition-gated (Enterprise/Education tiers); their presence is confirmed in the Admin console. #> [CmdletBinding()] param([int]$MaxUsers = 500, [int]$MaxFiles = 500)

GWSEC-Remediation.ps1

Purpose: Remediates the scriptable Google Workspace security findings surfaced by GWSEC-Discovery.ps1 — primarily tightening broadly-shared Drive items (removing public 'anyone with link' and domain-wide permissions) so exposed content is no longer over-shared. Safe by default: it previews every change and applies nothing unless you pass -Apply. Console-only baseline settings (2SV enforcement, session control, sharing defaults, DLP rules, CAA assignments) are NOT changed here — those are set in the Admin console per the Implementation Guide; this script prints the exact path for each.

HOW TO RUN Preview (default): powershell -ExecutionPolicy Bypass -File .\GWSEC-Remediation.ps1 Apply: powershell -ExecutionPolicy Bypass -File .\GWSEC-Remediation.ps1 -Apply Requires a Google super-admin OAuth access token in GOOGLE_OAUTH_TOKEN. Preview needs drive.metadata.readonly; -Apply needs the drive scope (permission delete). Scope to a pilot OU by exporting the target file IDs from Discovery first. EXPECTED RESULTS Without -Apply: a WHATIF list of the public/domain-wide Drive permissions that WOULD be removed, and the console paths for the settings this script does not touch. With -Apply: those broad permissions are removed and each action is logged. Re-run GWSEC-Discovery.ps1 / GWSEC-Validation.ps1 to confirm the exposure is gone. .NOTES White-label — the repeatable way. Read-only until -Apply is passed (default -WhatIf). Only removes broad ('anyone'/'domain') Drive permissions; it never deletes files or user-specific access. Baseline/DLP/CAA console settings are set in the Admin console, not here. #> [CmdletBinding(SupportsShouldProcess=$true, ConfirmImpact='High')] param([switch]$Apply, [int]$MaxFiles = 500)

How to run: Preview (default): powershell -ExecutionPolicy Bypass -File .\GWSEC-Remediation.ps1 Apply: powershell -ExecutionPolicy Bypass -File .\GWSEC-Remediation.ps1 -Apply Requires a Google super-admin OAuth access token in GOOGLE_OAUTH_TOKEN. Preview needs drive.metadata.readonly; -Apply needs the drive scope (permission delete). Scope to a pilot OU by exporting the target file IDs from Discovery first. EXPECTED RESULTS Without -Apply: a WHATIF list of the public/domain-wide Drive permissions that WOULD be removed, and the console paths for the settings this script does not touch. With -Apply: those broad permissions are removed and each action is logged. Re-run GWSEC-Discovery.ps1 / GWSEC-Validation.ps1 to confirm the exposure is gone. .NOTES White-label — the repeatable way. Read-only until -Apply is passed (default -WhatIf). Only removes broad ('anyone'/'domain') Drive permissions; it never deletes files or user-specific access. Baseline/DLP/CAA console settings are set in the Admin console, not here. #> [CmdletBinding(SupportsShouldProcess=$true, ConfirmImpact='High')] param([switch]$Apply, [int]$MaxFiles = 500)

GWSEC-Report.ps1

Purpose: Read-only reporting of Google Workspace security-posture coverage across all organizational units: per-OU 2SV enrollment coverage and broad-Drive-sharing exposure, plus a checklist of the edition-gated DLP and Context-Aware Access surfaces to confirm in the Admin console. Use it to see what is applied, what is missing, and which OUs are tracked exceptions as you expand the posture fleet-wide. Optionally writes a CSV. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\GWSEC-Report.ps1 [-CsvPath .\gwsec-coverage.csv] Requires a Google super-admin OAuth access token in GOOGLE_OAUTH_TOKEN with READ-ONLY scopes: admin.directory.user.readonly, admin.directory.orgunit.readonly, drive.metadata.readonly. EXPECTED RESULTS A coverage table (one row per OU: users, 2SV-enrolled, 2SV coverage %) and a fleet broad-sharing count, with a note listing the DLP/CAA/session surfaces to confirm per OU. PASS = high 2SV coverage and no untracked broad sharing across OUs. Rows below target are the exceptions to track and remediate. .NOTES White-label — the repeatable way. Read-only against the Admin Directory & Drive metadata APIs. DLP-for-Drive/Gmail and Context-Aware Access coverage is edition-gated and confirmed in the Admin console; this report frames coverage and points to where to verify the gated surfaces. #> [CmdletBinding()] param([string]$CsvPath)

How to run: powershell -ExecutionPolicy Bypass -File .\GWSEC-Report.ps1 [-CsvPath .\gwsec-coverage.csv] Requires a Google super-admin OAuth access token in GOOGLE_OAUTH_TOKEN with READ-ONLY scopes: admin.directory.user.readonly,

admin.directory.orgunit.readonly, drive.metadata.readonly. EXPECTED RESULTS A coverage table (one row per OU: users, 2SV-enrolled, 2SV coverage %) and a fleet broad-sharing count, with a note listing the DLP/CAA/session surfaces to confirm per OU. PASS = high 2SV coverage and no untracked broad sharing across OUs. Rows below target are the exceptions to track and remediate. .NOTES White-label — the repeatable way. Read-only against the Admin Directory & Drive metadata APIs. DLP-for-Drive/Gmail and Context-Aware Access coverage is edition-gated and confirmed in the Admin console; this report frames coverage and points to where to verify the gated surfaces. #> [CmdletBinding()] param([string]$CsvPath)

GWSEC-Set-ScopeTargeting.ps1

Purpose: Creates (idempotently) the Google Workspace organizational unit used to scope the controlled security-posture rollout, following the solution naming convention so the hardening baseline, DLP rules, and Context-Aware Access assignments can be targeted and rolled back consistently: Security Baseline - Pilot An existing OU (matched by path) is reused, not duplicated. Users are NOT moved — move a few representative pilot users (a super-admin test account, a power user, a field/mobile user) into the OU by hand. Then scope 2SV, session control, sharing, DLP, and CAA to this OU in the Admin console per the Implementation Guide. HOW TO RUN Report only (default): powershell -ExecutionPolicy Bypass -File .\GWSEC-Set-ScopeTargeting.ps1 Apply: powershell -ExecutionPolicy Bypass -File .\GWSEC-Set-ScopeTargeting.ps1 -Apply Requires a Google super-admin OAuth access token in GOOGLE_OAUTH_TOKEN with the scope admin.directory.orgunit (create/read organizational units). Optional -ParentOrgUnitPath sets the parent (default '/'). EXPECTED RESULTS The pilot OU 'Security Baseline - Pilot' exists (created if missing, reused if present), with its path printed for use when scoping baseline/DLP/CAA settings in the Admin console. Nothing is changed unless -Apply is passed. .NOTES White-label — the repeatable way. Safe by default (-WhatIf); pass -Apply to create the OU. The OU name uses ASCII hyphens; keep it verbatim across scripts and Admin-console targeting so validation, reporting, and rollback stay consistent. #> [CmdletBinding(SupportsShouldProcess=$true, ConfirmImpact='Medium')] param([string]$OrgUnitName = 'Security Baseline - Pilot', [string]$ParentOrgUnitPath = '/', [switch]$Apply)

How to run: Report only (default): powershell -ExecutionPolicy Bypass -File .\GWSEC-Set-ScopeTargeting.ps1 Apply: powershell -ExecutionPolicy Bypass -File .\GWSEC-Set-ScopeTargeting.ps1 -Apply Requires a Google super-admin OAuth access token in GOOGLE_OAUTH_TOKEN with the scope admin.directory.orgunit (create/read organizational units). Optional -ParentOrgUnitPath sets the parent (default '/'). EXPECTED RESULTS The pilot OU 'Security Baseline - Pilot' exists (created if missing, reused if present), with its path printed for use when scoping baseline/DLP/CAA settings in the Admin console. Nothing is changed unless -Apply is passed. .NOTES White-label — the repeatable way. Safe by default (-WhatIf); pass -Apply to create the OU. The OU name uses ASCII hyphens; keep it verbatim across scripts and Admin-console targeting so validation, reporting, and rollback stay consistent. #> [CmdletBinding(SupportsShouldProcess=$true, ConfirmImpact='Medium')] param([string]$OrgUnitName = 'Security Baseline - Pilot', [string]$ParentOrgUnitPath = '/', [switch]$Apply)

GWSEC-Validation.ps1

Purpose: Read-only check that a given organizational unit meets the intended Google Workspace security posture: users in the OU are enrolled in 2SV, the OU has no broadly-shared Drive items, and the edition-gated DLP and Context-Aware Access surfaces are present to confirm rule/assignment state (monitor vs enforce, audit vs block) in the Admin console. Run it on the pilot OU (Security Baseline - Pilot)

before expanding, and per OU on each expansion wave. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\GWSEC-Validation.ps1 -OrgUnitPath '/Security Baseline - Pilot' Requires a Google super-admin OAuth access token in GOOGLE_OAUTH_TOKEN with READ-ONLY scopes: admin.directory.user.readonly, admin.directory.orgunit.readonly, drive.metadata.readonly. Provide the OU path exactly as it appears in Directory > Organizational units. EXPECTED RESULTS A per-check PASS / FAIL line for the OU (2SV enrollment, broad-sharing, DLP/CAA presence) and an overall result. PASS on all baseline checks is the gate to promote DLP audit->block and CAA monitor->enforce, and to expand past the pilot. FAIL lines name the exact setting to fix. .NOTES White-label — the repeatable way. Read-only against the Admin Directory & Drive metadata APIs. DLP-for-Drive/Gmail rule state and Context-Aware Access assignment mode (monitor/enforce) are edition-gated and confirmed in the Admin console — this script reports where to verify them. #> [CmdletBinding()] param([Parameter(Mandatory=$true)][string]$OrgUnitPath)

How to run: powershell -ExecutionPolicy Bypass -File .\GWSEC-Validation.ps1 -OrgUnitPath '/Security Baseline - Pilot' Requires a Google super-admin OAuth access token in GOOGLE_OAUTH_TOKEN with READ-ONLY scopes: admin.directory.user.readonly, admin.directory.orgunit.readonly, drive.metadata.readonly. Provide the OU path exactly as it appears in Directory > Organizational units. EXPECTED RESULTS A per-check PASS / FAIL line for the OU (2SV enrollment, broad-sharing, DLP/CAA presence) and an overall result. PASS on all baseline checks is the gate to promote DLP audit->block and CAA monitor->enforce, and to expand past the pilot. FAIL lines name the exact setting to fix. .NOTES White-label — the repeatable way. Read-only against the Admin Directory & Drive metadata APIs. DLP-for-Drive/Gmail rule state and Context-Aware Access assignment mode (monitor/enforce) are edition-gated and confirmed in the Admin console — this script reports where to verify them. #> [CmdletBinding()] param([Parameter(Mandatory=$true)][string]$OrgUnitPath)